

Injection útoky (XSS / Command Injection / Script Injection)

V mojom projekte sa venujem téme injection útokov, ktoré patria medzi najčastejšie a najnebezpečnejšie bezpečnostné zraniteľnosti webových aplikácií a informačných systémov. Injection útok vzniká vtedy, keď aplikácia nesprávne spracúva vstup od používateľa a umožní útočníkovi vložiť škodlivý kód, ktorý systém následne vykoná.

Injection Attacks – modul

Tento modul sa zameriava na rôzne typy injection zraniteľností a ich zneužitie v praxi. Obsahuje viacero podtém, napríklad:

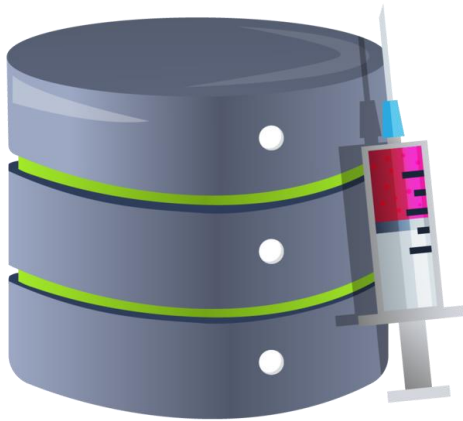
- Advanced SQL Injection
- NoSQL Injection
- XXE Injection
- Server-Side Template Injection
- LDAP Injection

Cieľom modulu je naučiť používateľa rozpoznať zraniteľnosti a pochopiť ich dopad na bezpečnosť webových aplikácií. Modul využíva praktické scenáre, kde si používateľ skúša útoky aj obranu.

Čo som sa naučil:

- ako fungujú rôzne injection útoky
- aké chyby vo validácii vstupu ich spôsobujú

- prečo môžu viesť až k úniku dát alebo RCE



XSS miestnosť (axss / xss)

Táto miestnosť sa detailne venuje Cross-Site Scriptingu (XSS), ktorý patrí medzi najčastejšie webové zraniteľnosti. XSS umožňuje útočníkovi vložiť škodlivý skript do webovej stránky, ktorý sa následne spustí v prehliadači obete.

Hlavné typy XSS

V laboratóriu som pracoval s tromi hlavnými typmi:

Reflected XSS

- škodlivý vstup sa okamžite odrazí v odpovedi
- často cez URL parameter

Stored XSS

- škodlivý kód sa uloží do databázy
- spustí sa každému používateľovi

DOM-based XSS

- zraniteľnosť je priamo v JavaScripte v prehliadači
- server nemusí byť zapojený

Po úspešnom útoku môže útočník napríklad:

- ukradnúť session cookies
- prevziať účet používateľa
- meniť obsah stránky
- presmerovať obeť

XSS – Advent of Cyber miestnosť

Táto praktická úloha bola zameraná na využitie XSS v simulovanej webovej aplikácii. Pred začiatkom bolo potrebné spustiť AttackBox a cieľový server.

V úlohe sa pracovalo najmä s:

- Reflected XSS
- Stored XSS
- analýzou vstupných polí

Laboratórium ukázalo, že ak aplikácia nesprávne filtruje vstup používateľa, škodlivý JavaScript môže byť interpretovaný ako legitímny kód, čo vedie napríklad ku krádeži prihlasovacích údajov alebo k impersonácii používateľa.